MOBİL TEKNOLOJİLER DERSİ PROJE & GÜVENLİK RAPORU

screentime-guard: Offline-First Ekran Süresi Takip ve Uyarı Sistemi

Flutter + Kotlin Native Android İstemcisi, FastAPI Mikroservisi, Gerçek Cihaz Doğrulaması ve Siber Güvenlik Analizi

MOBİL TEKNOLOJİ	MİKROSERVİS	GERÇEK TEST CİHAZI	OTOMATİK TESTLER
Flutter 3.47 + Kotlin	Python 3.13 + FastAPI	Xiaomi 14T (HyperOS)	18 / 18 Başarılı (%100)

1. Giriş ve Problemin Tanımı

Akıllı telefonların günlük yaşamda yoğun kullanımı, kullanıcıların farkında olmadan ekran başında saatler geçirmesine ve özellikle gece geç saatlerde (örneğin `23:00 – 06:00` aralığında) uyku düzeninin bozulmasına yol açmaktadır. Mevcut ticari çözümlerin birçoğu ya tamamen bulut bağımlı çalışmakta (internet kesildiğinde kuralları uygulayamamakta) ya da aşırı sistem kaynağı tüketmektedir.

`screentime-guard` projesinin temel hedefleri şunlardır:

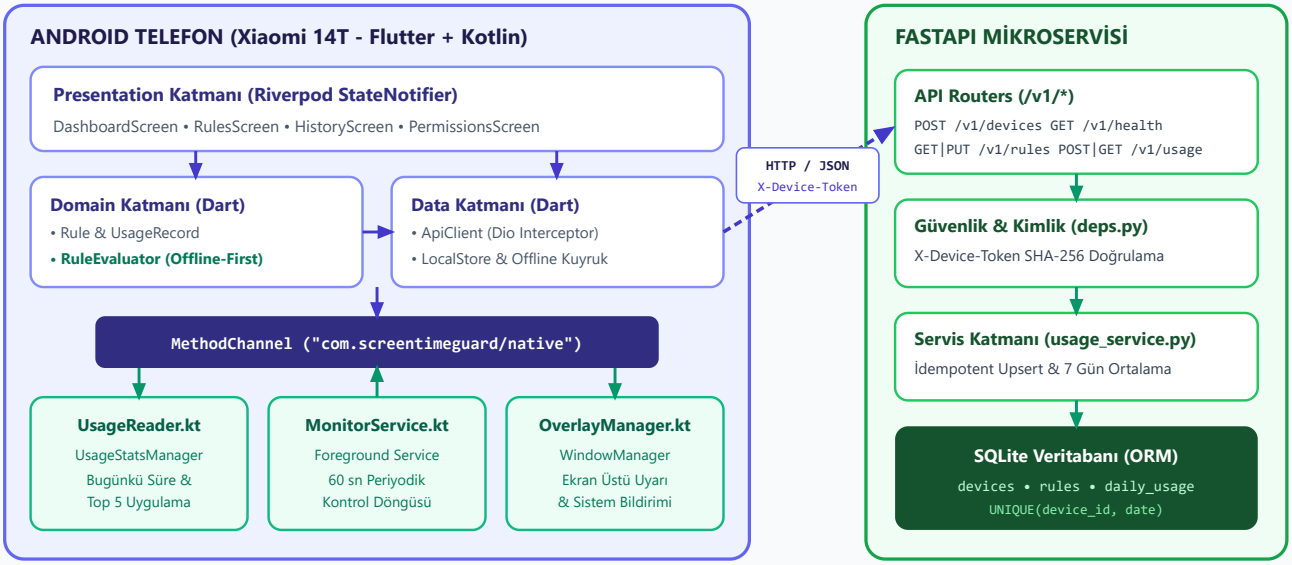
1. **Gerçek Ekran Süresi Ölçümü:** Android işletim sisteminin `UsageStatsManager` servisi üzerinden günlük toplam ekran süresini ve en çok kullanılan ilk 5 uygulamayı (`top_apps`) paket bazında ölçmek.
2. **Proaktif Uyarı Mekanizması:** Günlük limitin %80'ine ulaşıldığında (`warn_80`), limit aşıldığında (`limit_exceeded`) veya gece kesme saati aralığında (`in_cutoff_window`) kullanıcıyı **Sistem Bildirimi (`notify`)** ya da **Ekran Üstü Uyarı Penceresi (`overlay`)** ile uyarmak.
3. **Offline-First Mimari ve İdempotent Senkronizasyon:** İnternet olmasa bile kural değerlendirmesini telefonda kesintisiz yürütmek; kullanım istatistiklerini yerel kuyrukta bekletip bağlantı geldiğinde FastAPI mikroservisine idempotent olarak aktarmak.

2. Teknoloji Seçimleri ve Mimari Gerekçeler

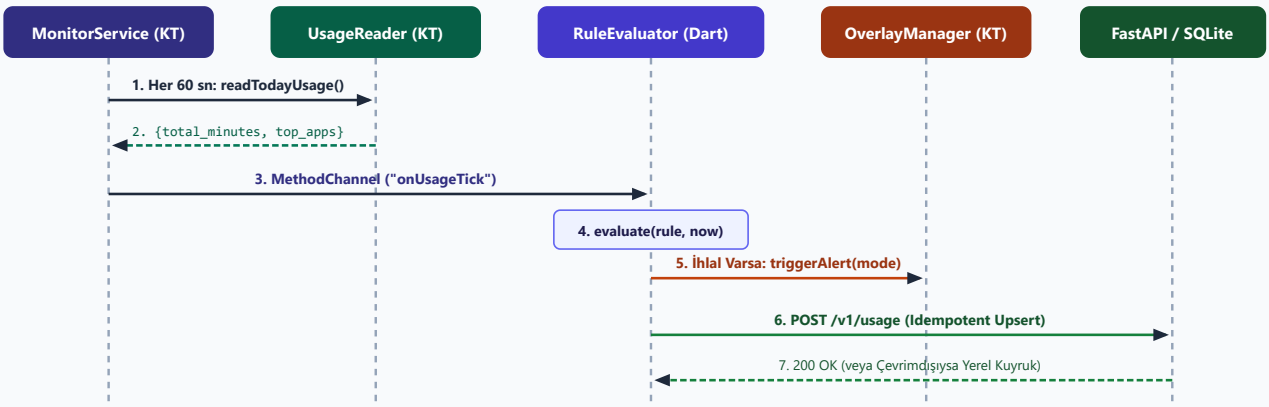
Katman	Seçilen Teknoloji	Seçim Gerekçesi
Mobil Arayüz & İş Mantığı	Flutter (Dart 3.13)	Tek kod tabanıyla modern Material 3 arayüzü geliştirme ve iş mantığının (`RuleEvaluator`) emülatörsüz birim testleriyle saniyeler içinde doğrulanabilmesi.
Android Native Katmanı	Kotlin (`MethodChannel`)	Flutter'ın doğrudan erişemediği Android sistem API'lerine (`UsageStatsManager` , `ForegroundService` , `WindowManager` Overlay) minimum kodla erişim.
Durum Yönetimi (State)	Riverpod (`StateNotifier`)	Temiz bağımlılık enjeksiyonu (Dependency Injection), test edilebilirlik ve 4 ana ekran arasında reaktif durum akışı.
HTTP İstemcisi	Dio	`InterceptorsWrapper` ile her HTTP isteğine otomatik `X-Device-Token` başlığı ekleme ve dinamik sunucu adresi yönetimi.
Backend Mikroservisi	Python 3.13 + FastAPI	Yüksek performans, Pydantic v2 ile otomatik JSON şema doğrulaması ve etkileşimli OpenAPI (`/docs`) arayüzü.
Veritabanı & ORM	SQLite + SQLAlchemy 2.0	Kurulum gerektirmeyen gömülü yapı, parametreli sorgularla SQL enjeksiyon koruması ve `(device_id, date)` benzersizlik kısıtı.

> **Neden iOS Yerine Android Seçildi?**
> iOS işletim sistemi, katı kum havuzu (sandbox) kısıtlamaları nedeniyle bir uygulamanın diğer uygulamaların kullanım sürelerini okumasını ve ekran üstü pencere açmasını engeller (Apple *Screen Time / FamilyControls API* özel kurumsal onay gerektirir). Android ise kullanıcının açık onayıyla (`PACKAGE_USAGE_STATS` ve `SYSTEM_ALERT_WINDOW`) bu sistem servislerine erişime olanak tanır.

3. Sistem Mimarisi ve Veri Akışı Şemaları



Şekil 1: screentime-guard Genel Sistem ve Katman Mimarisi Diyagramı



Şekil 2: 60 Saniyelik Periyodik İzleme, Kural Değerlendirme ve Senkronizasyon Sıralama Diyagramı

3.1. Gece Yarısını Aşan Kesme Saati (Cutoff Window) Algoritması

Kullanıcının belirlediği kesme saati `23:00 – 06:00` gibi gece yarısını aşabilir. `RuleEvaluator.isInCutoffWindow` fonksiyonu saatleri gece yarısından itibaren geçen dakikaya (*M = saat × 60 + dakika*, `0..1439`) dönüştürerek aşağıdaki karar kuralını uygular:

- Aynı Gün İçi Aralık ($M_{start} < M_{end}$, örn. 01:00 – 05:00): $M_{start} \le M_{now} < M_{end}$
- Gece Yarısını Aşan Aralık ($M_{start} > M_{end}$, örn. 23:00 – 06:00): $M_{now} \ge M_{start}$ VEYA $M_{now} < M_{end}$

4. Gerçek Cihaz (Xiaomi 14T) Canlı Doğrulama Sonuçları

Uygulama emülatör yerine doğrudan fiziksel **Xiaomi 14T (model: `2406APNFAG`)** cihazına kurulmuş ve gerçek kullanım verileriyle test edilmiştir:

Test Adımı	Gerçek Cihazda Gözlemlenen Davranış	SQLite Veritabanı (`screentime_guard.db`) Kaydı
1. Cihaz Kaydı (`POST /v1/devices`)	İlk açılışta otomatik kayıt yapıldı ve üretilen `X-Device-Token` yerel hafızaya kaydedildi.	`id: abf3b855-409e-4b77-b323-e0d10467a4a9` `name: Android Cihazım`
2. Kural Güncelleme (`PUT /v1/rules`)	Kurallar ekranından günlük limit **255 dk** ve uyarı modu **overlay** seçilip kaydedildi.	`daily_limit_min: 255`, `cutoff: 23:00-06:00`, `mode: overlay`
3. Süre Okuma (`UsageReader.kt`)	`UsageStatsManager` ile Xiaomi 14T'nin bugünkü gerçek kullanımı (**246 dk**) okundu.	`date: 2026-10-22`, `total_minutes: 246`
4. En Çok Kullanılanlar (`top_apps`)	Chrome (58 dk), Google (39 dk), WhatsApp (34 dk), Reddit (29 dk), MIUI Home (28 dk).	JSON dizisi olarak `daily_usage.top_apps` sütununa yazıldı.
5. Kural & Overlay Uyarısı	`246 dk ≥ 204 dk` (%80 eşiği) olduğundan `warn_80` durumu ve limit düşürüldüğünde ekran üstü **Overlay** penceresi tetiklendi.	15 dakikalık *cooldown* mekanizması ile tekrarlı uyarı spam'i önlendi.

5. Siber Güvenlik Analizi ve Otomatik Test Sonuçları

Uygulama ve mikroservis **OWASP API Security Top 10 (2023)** ve **OWASP Mobile Top 10** standartlarına göre denetlenmiş; hem fonksiyonel hem de siber güvenlik doğrulama testleri (`pytest` ve `flutter test`) %100 başarıyla geçmiştir.

5.1. Otomatik Güvenlik ve Birim Testleri Sonuç Tablosu (18 / 18 Başarılı)

Test Adı / Senaryo	OWASP Kategorisi	Doğrulanan Güvenlik / İş Mantığı Mekanizması	Sonuç
`test_token_entropy_and_sha256_storage`	API2: Broken Authentication	`secrets.token_urlsafe(32)` ile 256-bit entropili token üretimi ve veritabanında açık token yerine yalnızca 64 karakterlik **SHA-256 hash** saklanması.	**PASSED**
`test_device_data_isolation`	API1: BOLA / IDOR	Cihazlar arası tam veri izolasyonu: A cihazının B cihazına ait kuralları veya kullanım geçmişini okuyamaması ve değiştirememesi.	**PASSED**
`test_input_boundary_and_payload_limits`	API4: Resource Consumption	1440 dakikadan büyük sürelerin, negatif değerlerin, 100 karakterden uzun cihaz adlarının ve 20'den fazla `top_apps` elemanının `422` ile reddedilmesi.	**PASSED**
`test_special_characters_handled_safely_by_orm`	API8: Injection (SQLi)	`X-Device-Token` başlığında özel SQL karakterlerinin SQLAlchemy 2.0 parametreli sorguları tarafından güvenle işlenmesi.	**PASSED**

Test Adı / Senaryo	OWASP Kategorisi	Doğrulanan Güvenlik / İş Mantığı Mekanizması	Sonuç
`test_error_responses_do_not_leak_internals`	API8: Misconfiguration	401, 404 ve 422 yanıtlarında Python *Traceback* veya iç dosya yollarının sızdırılmaması; standart `{"error": {"code", "message"}}` zarfı.	**PASSED**
`test_api.py` (7 Fonksiyonel Test)	API Sözleşme Doğrulaması	`/v1/health`, cihaz kaydı, kural okuma/güncelleme, aynı gün için idempotent `POST /v1/usage` ve 7 günlük ortalama hesabı.	**7/7 PASSED**
`rule_evaluator_test.dart` & `offline_sync_queue_test.dart`	Mobil İş Mantığı & Offline Kuyruk	Gece yarısını aşan kesme saati (`23:30` ve `02:15`), %80 uyarısı, limit aşımı ve çevrimdışı kuyruk idempotency doğrulaması.	**6/6 PASSED**

5.2. Kod Üzerinde Uygulanan Güvenlik Sertleştirmeleri (Hardening)

- **Veri Minimizasyonu (Privacy by Design):** Sistem kullanıcıdan ad, e-posta, şifre veya ekran içeriği toplamaz; yalnızca anonim cihaz UUID'si, toplam dakika ve uygulama paket adları işlenir.
- **Android Bileşen ve Yedekleme Koruması (`AndroidManifest.xml`):** `MonitorService` için `android:exported="false"` tanımlanarak dış uygulamaların servise müdahalesi engellenmiş; `android:allowBackup="false"` ile `adb backup` üzerinden yerel token sızıntısı kapatılmıştır.
- **Bellek/Veritabanı Şişirme (DoS) Koruması (`schemas.py`):** `UsageUpsertRequest.top_apps` alanına `max_length=20` sınırı getirilmiştir.

5.3. Üretim Ortamı (Production) İçin Güvenlik Yol Haritası

Bulgu Başlığı	Risk Seviyesi	Mevcut Durum ve Üretim Ortamı (Production) Çözüm Önerisi
HTTP / Cleartext İletişim	**Orta (Mobile M5)**	Yerel ağda test için açık olan `usesCleartextTraffic="true"` ayarı üretimde kapatılmalı ve tüm API trafiği **HTTPS/TLS** üzerinden şifrelenmelidir.
Cihaz Kayıt Rate Limiting	**Orta (API4)**	Kimlik doğrulama gerektirmeyen `POST /v1/devices` uç noktasına sahte cihaz kaydı saldırılarını (flood) önlemek için IP bazlı hız sınırı (`5 istek/dk`) eklenmelidir.
Yerel Token Saklama	**Düşük/Orta (M9)**	Root yetkili cihazlara karşı `device_token` değerinin `SharedPreferences` yerine donanım destekli **Android Keystore** (`flutter_secure_storage`) içinde tutulması önerilir.

6. Karşılaşılan Zorluklar ve Gelecek Çalışmalar

- **Android Özel İzin Akışı:** `PACKAGE_USAGE_STATS` ve `SYSTEM_ALERT_WINDOW` izinleri standart çalışma zamanı izin penceresiyle alınamadığı için `AppOpsManager` ile anlık durum kontrolü yapan ve kullanıcıyı doğrudan ilgili sistem ayar sayfasına yönlendiren özel bir **İzinler Ekranı** geliştirilmiştir.
- **Android Pil Optimizasyonu:** Arka plan zamanlayıcılarının işletim sistemi tarafından durdurulmasını önlemek için `START_STICKY` bayraklı ve kalıcı bildirimli **Foreground Service (`MonitorService`)** kullanılmıştır.
- **Gelecek Çalışmalar:** `AccessibilityService` kullanılarak uygulama bazında özel limit/engelleme getirilmesi ve çoklu cihaz yönetimi için **Ebeveyn / Aile Paneli** eklenmesi planlanmaktadır.